



LAPORAN

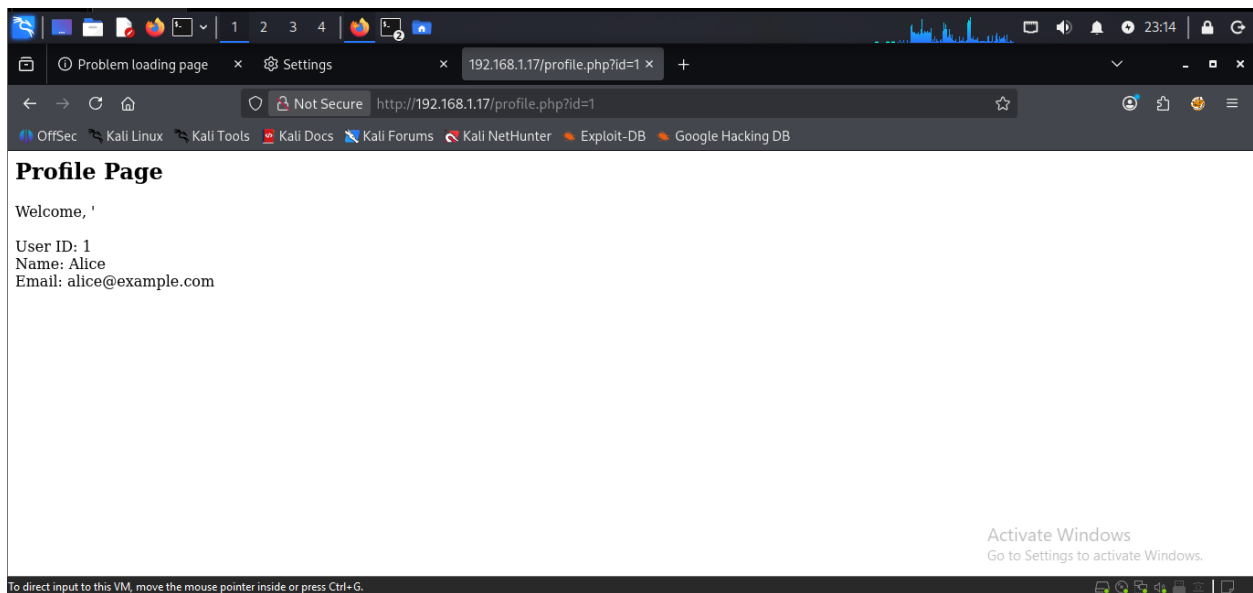
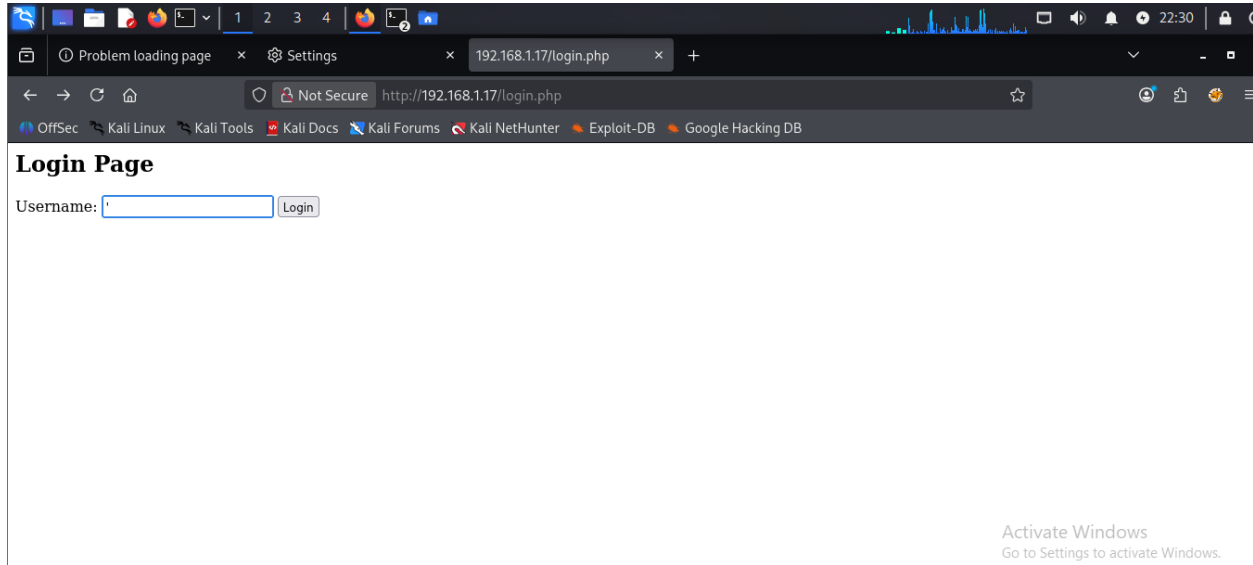
BROKEN ACCESS CONTROL (AG)

Bootcamp Cyber Security Batch 6

Disusun oleh : Adyatma Abigail

Mei 2026

Akses Tanpa Izin.

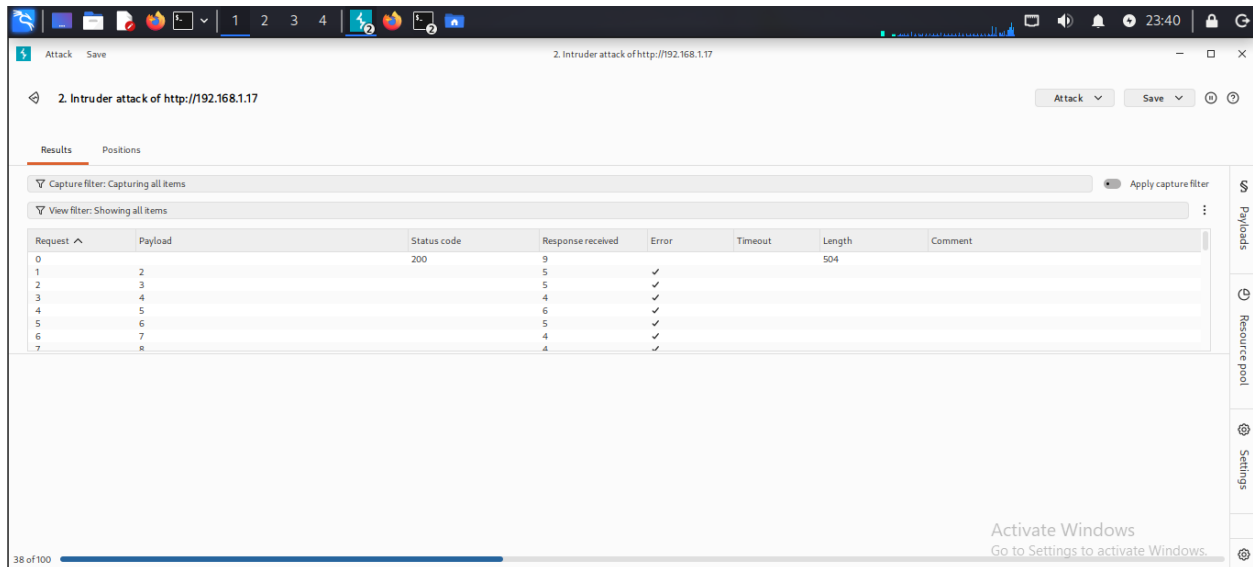


Pada panel login saya mencoba memasukkan username dengan menggunakan tanda petik dan ternyata berhasil login ke akun ID 1 dan mendapatkan juga email nya.

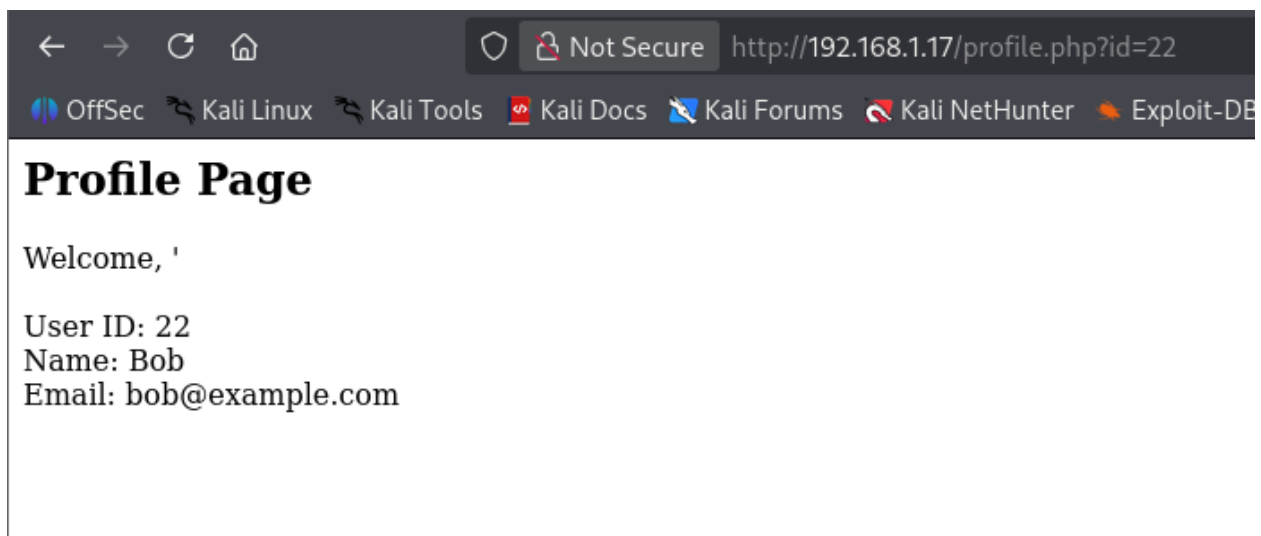
Eksploitasi IDOR (Insecure Direct Object Reference).

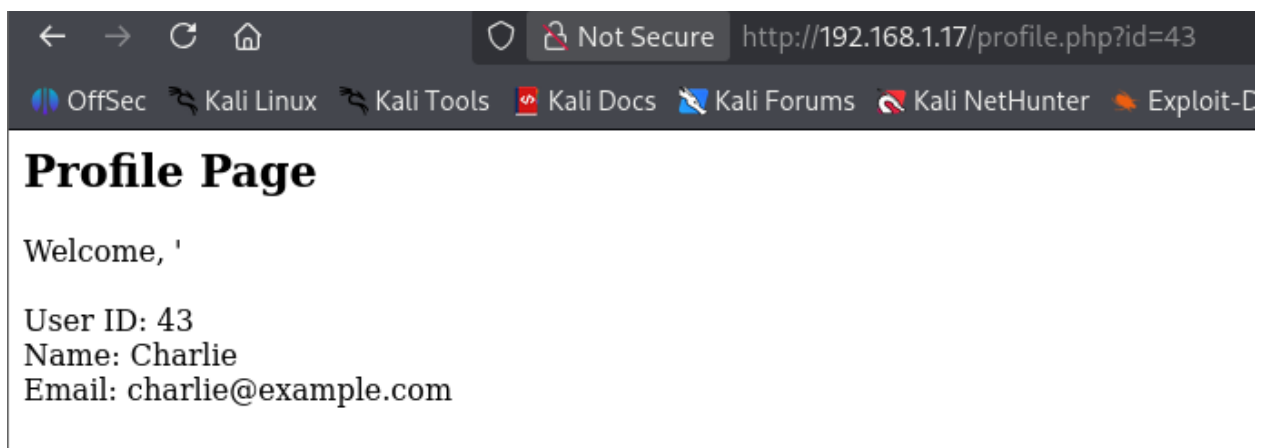
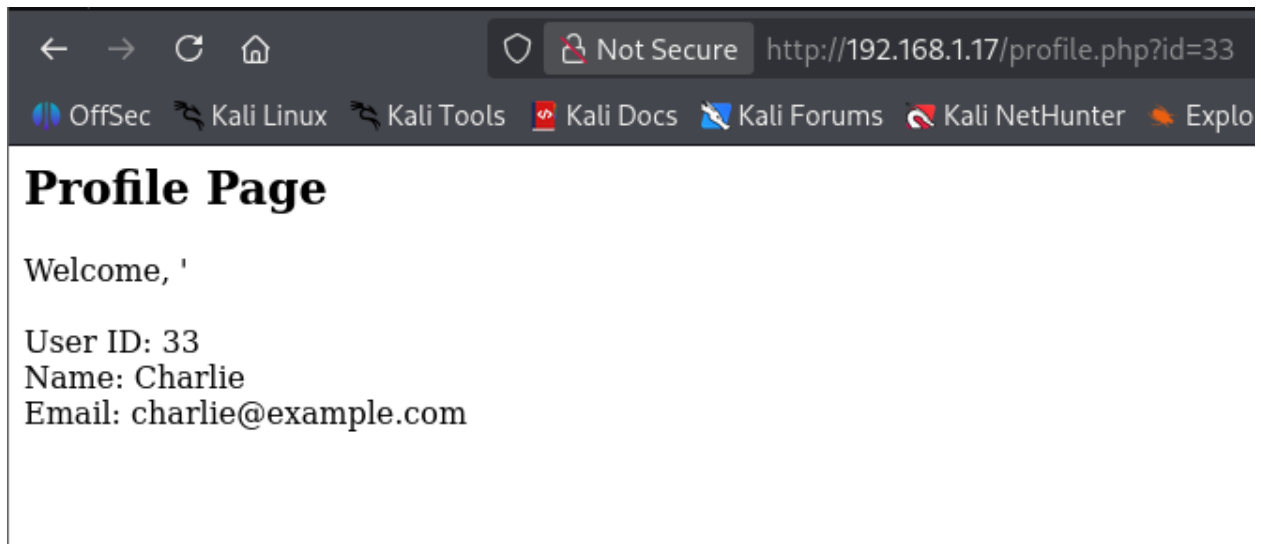
```
http://192.168.1.17/profile.php?id=1
```

Saya melihat adanya kemungkinan kerentanan bisa di IDOR pada request http di atas.



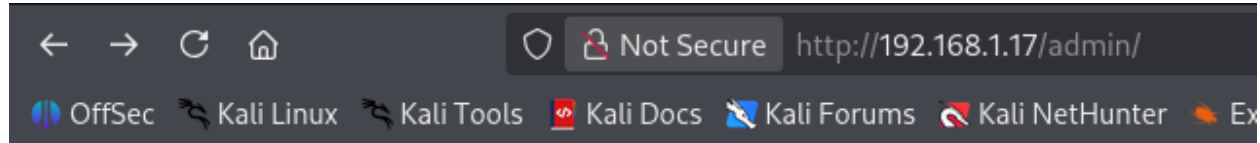
Lalu saya membuat payload dari burpsuit dengan cara mengetes http request pada id di atas saya mengetes mulai dari id 2 ke 100, dengan harapan menemukan akun yang dapat di input tanpa login ke akun yang punya.





Setelah saya memasang payload yang saya tes dari ID2 – ID101, saya menemukan ada beberapa id yang saya temukan dan dapat saya akses tanpa akses login. Dan berarti website ini sangat rentan terhadap IDOR.

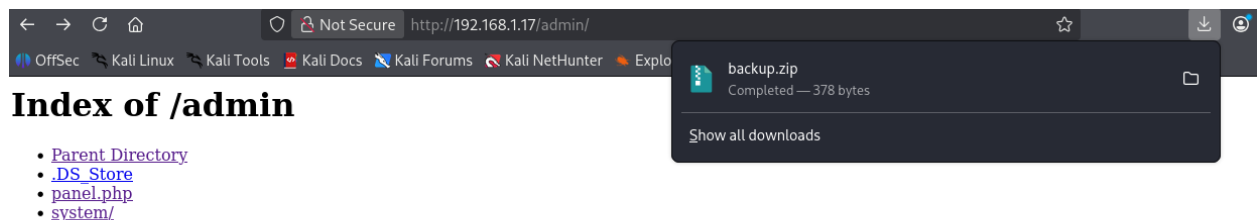
Download Resource yang Tersembunyi.



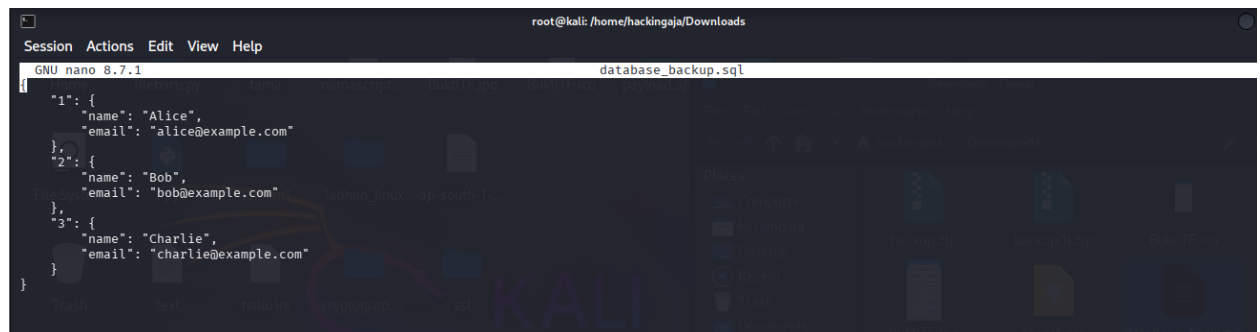
Index of /admin

- [Parent Directory](#)
- [.DS_Store](#)
- [panel.php](#)
- [system/](#)

Ketika saya hanya menambahkan admin kepada http request saya menemukan jelas bahwa bisa mengakses admin panes yang Dimana saya bisa masuk ke panel.php dan system/ dan dapat mendownload file.



Dan saya mendownload file tersebut dari system/.



Lalu saya bisa mengekstrak file sensitive mengani akun akun yang saya bisa dapat emal nya, ini sangat berbahaya karna Risiko apabila attacker mendapatkan hal seperti ini attacker bisa

Menyusun rencana phishing kepada email yang di dapatkan dan bisa juga attacker itu melakukan brute force kepada email yang di dapat berujung email di ambil ahli.

Enumerasi Hidden Resources.

```
(hackingaja@kali)-[~]
└─$ sudo dirb http://192.168.1.17/admin/ wordlistbac.txt -w

Index of /admin
DIRB v2.22
By The Dark Raver
-----
+ http://192.168.1.17/admin/panel.php (CODE:200|SIZE:73)
⇒ DIRECTORY: http://192.168.1.17/admin/system/

+ http://192.168.1.17/admin/system/backup.zip (CODE:200|SIZE:378)

END_TIME: Sat May 9 00:27:31 2026
DOWNLOADED: 104 - FOUND: 2
```

pada saat saya berhasil mengakses admin panel yang saya dapatkan pada gambar sebelumnya, saya melakukan pencarian file sensitif dengan menggunakan bantuan tool dirb dengan memasukkan perintah di atas, lalu saya mendapatkan hal serupa pada pencarian manual yaitu backup.zip yang isinya mengenai informasi nama dan email seseorang.

Menyusun Rekomendasi Mitigasi.

strategi mitigasi utama untuk mencegah IDOR:

1. Implementasi Kontrol Akses Berbasis Pengguna (Otorisasi)

- Validasi Otorisasi Setiap Objek: Jangan hanya memeriksa apakah pengguna sudah login (otentikasi), tetapi periksa apakah mereka memiliki hak akses ke objek spesifik yang diminta.
- Penerapan Prinsip Hak Akses Minimum (Least Privilege): Pastikan pengguna hanya dapat mengakses, mengubah, atau menghapus data yang menjadi milik mereka atau yang diizinkan oleh sistem.

2. Menggunakan Referensi Objek Tidak Langsung [\[1\]](#)

- Pemetaan Referensi Tidak Langsung: Gunakan pemetaan referensi objek tidak langsung (indirect object references). Contoh: alih-alih menggunakan ID ?invoice=1001 di URL, gunakan pemetaan sesi seperti ?invoice=session_id_3 yang tidak mudah ditebak atau dimanipulasi oleh pengguna.
- GUID atau ID Acak: Gunakan pengidentifikasi unik global (GUID/UUID) atau ID acak daripada ID urutan (1, 2, 3...) untuk mencegah *enumeration attack* (menebak ID lain)

3. Pengujian dan Pemantauan Keamanan

- Pengujian Otorisasi Manual: Gunakan dua atau lebih akun pengguna yang berbeda untuk memastikan satu pengguna tidak dapat mengakses data pengguna lain (misalnya, melalui customer_number atau ID item).

Soal Teori Broken Access Control.

Berikut adalah jawaban ringkas untuk pertanyaan Anda:

1. Broken Access Control adalah kelemahan keamanan di mana aplikasi gagal membatasi akses pengguna sesuai dengan hak yang seharusnya. Penyerang bisa mengakses data atau fitur yang bukan milik mereka.
2. Horizontal: Mengakses data milik pengguna lain dengan level yang sama (misal: User A melihat profil User B). Vertical: Mengakses fitur milik pengguna dengan level lebih tinggi (misal: User biasa mengakses panel Admin).

3. IDOR (Insecure Direct Object Reference) adalah jenis celah keamanan di mana pengguna bisa mengakses objek (data) secara langsung hanya dengan mengubah ID di parameter. Contoh: Mengubah URL `://aplikasi.com` menjadi `10102` untuk melihat tagihan orang lain.
4. Insecure ID manipulation (mengubah ID di URL/Body) dan Forced Browsing (mengakses URL tersembunyi seperti `/admin` secara manual).
5. Karena aplikasi seringkali hanya mengandalkan "kerahasiaan" URL atau parameter tersebut tanpa melakukan pengecekan otorisasi ulang di sisi server untuk memastikan pengguna berhak mengakses nilai baru tersebut.
6. Deny by Default berarti secara otomatis menolak semua permintaan akses, kecuali jika akses tersebut secara eksplisit diizinkan. Ini mencegah celah akses yang tidak sengaja terbuka.
7. Sangat berbahaya karena file backup sering kali berisi kode sumber (source code), file konfigurasi, hingga kredensial basis data yang memungkinkan penyerang mengambil alih seluruh sistem.
8. Agar Session ID tersebut mati dan tidak bisa digunakan kembali oleh penyerang (misal melalui *session hijacking*) untuk masuk ke akun pengguna setelah mereka selesai menggunakan layanan. [1, 2, 3, 4, 5]